

ANNEXE 3 : mise en place du protocole HTTPS

L'accès sécurisé à un site Web

Les sites web contiennent des données sensibles et sont accessibles de l'extérieur du réseau ; il est donc indispensable d'utiliser des protocoles d'échange sécurisés.

L'objectif est que les visiteurs puissent accéder à ces sites web avec le protocole HTTPS. Il est possible d'acheter, voir même d'obtenir gratuitement un certificat pour notre serveur Web mais la technique utilisée ici consiste à devenir notre propre autorité de certification qui délivrera ensuite le certificat signé pour notre serveur Web. Il est considéré ici que les notions de chiffrement et notamment de chiffrement asymétrique sont acquises. Vous trouverez ici la procédure pour mettre en œuvre une infrastructure de clé à l'échelle « réseau local » et pour configurer un serveur web avec le protocole SSL/TLS.

Le rôle de l'autorité de certification

Dans un système simplifié, l'Autorité de certification (AC ou CA) a pour rôle, après vérification de l'identité du demandeur du certificat, de signer, émettre et maintenir des certificats ainsi qu'une liste de révocation des dits certificats.

Elle doit, pour cela, posséder son propre certificat (auto-émis/auto-signé) qui permettra de valider le(s) certificat(s) émis.

Préparation du système

OpenSSL fournit une application pour créer des certificats client ou serveur.

- Vérifiez que le paquet « openssl » est installé.

OpenSSL s'appuie sur un fichier de configuration `/etc/ssl/openssl.cnf`

Toutes les commandes d'openssl vont chercher divers paramètres dans ce fichier (à adapter aux besoins) sauf si la ligne de commande donne d'autres directives.

Voici l'extrait qui nous intéresse :

```
[ CA_default ]
dir                = ./demoCA                # Where everything is kept
certs              = $dir/certs              # Where the issued certs are kept
crl_dir            = $dir/crl                # Where the issued crl are kept
database           = $dir/index.txt         # database index file
...
new_certs_dir      = $dir/newcerts          # default place for new certs.
certificate         = $dir/cacert.pem        # The CA certificate
serial             = $dir/serial            # The current serial number
...
crl                = $dir/crl.pem           # The current CRL
private_key         = $dir/private/cakey.pem # The private key
```

L'arborescence à créer (ou à compléter) est donc la suivante :

- *certs* accueille les certificats nouvellement créés à envoyer aux demandeurs
- *crl* accueille les certificats révoqués
- *newcerts* accueille une copie des certificats que l'organisation garde
- *private* accueillera les clés privées

Les fichiers sont les suivants :

- *private/cakey.pem* est la clé privée de l'autorité de certification
- *index.txt* va contenir la liste des certificats que l'on générera
- *serial* contient le numéro de série du prochain certificat créé : il est donc nécessaire de l'initialiser à « 1 »

En ce qui concerne les clés privées, il est important de comprendre qu'une véritable infrastructure de clés (c'est à dire un organisme de tiers de confiance qui délivre des certificats) ne détient pas les clés privées correspondantes aux clés publiques contenues dans les certificats ; on est ici dans un cas spécifique où l'on a deux casquettes : le prestataire (le tiers de confiance qui délivre un certificat) et le client (qui demande un certificat).

Il est nécessaire d'adapter le système et le fichier de configuration d'openssl aux besoins. La clé de l'autorité de certification, les demandes de certificats et certificats (émis et révoqués) seront créés dans le dossier `/etc/ssl`.

- Changez la valeur de la variable « `dir` » dans le fichier `/etc/ssl/openssl.cnf` (`./demoCA` à remplacer par `/etc/ssl`).
- Créez les dossiers strictement nécessaires dans le répertoire `/etc/ssl` (qui accueillera les demandes et les nouveaux certificats créés).
- Créez un fichier vide `index.txt` et un fichier `serial` avec "01" écrit dedans.

Génération du certificat de l'autorité de certification

La génération du certificat de l'autorité de certification se réalise en deux étapes.

Première étape : création de la clé privée de l'autorité de certification

La commande `openssl genrsa -des3 -out chemin/akey.pem 4096` crée un fichier `akey.pem` contenant la clé privée de 4096 bits protégée par une « pass phrase » (option `-des3`)

Cette « pass phrase » (mot de passe long qui peut contenir des espaces) sera demandée à chaque utilisation de la clé.

- Créez la clé privée de l'autorité de certification dans le dossier `/etc/ssl/private` (attention de ne pas oublier votre pass phrase).
- Consultez (uniquement en lecture) avec un éditeur de texte le fichier produit (le format « PEM » permet d'obtenir un fichier constitué de caractères lisibles).
- Protégez la clé privée de l'autorité de certification en accordant uniquement des droits de lecture à l'utilisateur « root ».

Deuxième étape : génération du certificat auto-signé de l'autorité de certification

Il est possible de créer en une seule commande, à partir de cette clé, un certificat x509 auto-signé :
`openssl req -new -x509 -days durée_en nbre_jours -key chemin/akey.pem -out chemin/nom_certificat.pem`

req -new : demande d'un nouveau certificat

-x509 : le certificat demandé est auto-signé

-days durée_en nbre_jours : la durée de validité du certificat sera du nombre de jours spécifié

-key chemin/akey.pem : le chemin vers la clé privée à partir de laquelle sera généré le certificat contenant la clé publique correspondante.

-out chemin/nom_certificat.pem : création d'un fichier de nom `nom_certificat.pem` (qui sera le certificat auto-signé de l'autorité de certification) dans `/etc/ssl` (voir fichier `/etc/ssl/openssl.conf`)

Le mot de passe demandé est celui de la « pass phrase » saisie précédemment puisque vous utilisez la clé privée que vous avez protégée.

Il faut ensuite donner des renseignements sur l'autorité de certification :

Country Name (2 letter code) [AU]: **FR**

State or Province Name (full name) [Some-State]: **FRANCE**

Locality Name (eg, city) : **Montauban**

Organization Name (eg, company) [Internet Widgits Pty Ltd]: **SODECAF**

Organizational Unit Name (eg, section) []:

Common Name (eg, YOUR name) []: **CA Sodecaf France**

Email Address []: **webmaster@sodecaf.fr**

Remarque : la valeur de ces champs peut être saisie comme valeur par défaut dans `openssl.conf`

Ce certificat va permettre de vérifier l'authenticité et la validité du certificat du serveur Web.

- Créez le certificat de l'autorité de certification auto-signé, valide pour 5 ans et nommé `/etc/certs/cacert.pem` et consultez-le.

Génération du certificat du serveur Web

Cette génération s'effectue en trois étapes.

Première étape : création de la clé privée du serveur

On génère la clé privée de la même manière que précédemment mais sans la protéger par une « pass phrase » (sans l'option -des3) car sinon cette dernière sera demandée à chaque lancement d'Apache2 !

- Créez la clé privée `srvwebkey.pem` du serveur web dans le dossier `/etc/ssl/private` de la machine `srvweb` (attention, pas d'option -des3 !).

A partir de la clé privée générée, il s'agit de créer un fichier de **demande de certificat**.

Deuxième étape : génération de la demande de certificat du serveur web

Pour générer le CSR (Certificate Signing Request) c'est à dire **le formulaire de demande de certificat à partir de la clé privée préalablement créée**, la commande est la suivante :

```
openssl req -new -key chemin/nom_clé_privée.pem -out chemin/nom_fichier_dem.pem
```

Le système va demander de **saisir des champs** ;

Country Name (2 letter code) [AU]: **FR**

State or Province Name (full name) [Some-State]: **France**

Locality Name (eg, city) []: **Montauban**

Organization Name (eg, company) [Internet Widgits Pty Ltd]: **SODECAF**

Organizational Unit Name (eg, section) []:

Common Name (eg, YOUR name) []: **sodecaf.fr**

Email Address []: **webmaster@sodecaf.fr**

Ce n'est pas la peine de saisir d'autres "extra attributes"...

Soyez très vigilant sur le Common Name (CN) : celui-ci doit correspondre exactement au nom pleinement qualifié (nom DNS : celui que vous allez saisir dans l'URL de votre serveur qui correspond aussi à la directive `ServerName` dans le fichier de configuration d'Apache).

Remarque : il est possible d'utiliser un autre champ que CN, le champ « `subjectAltName` » pour spécifier le nom DNS du serveur. Ce dernier champ permet en outre de préciser un ou plusieurs noms DNS (ceux correspondant aux différents `virtual hosts`). Ce qui implique qu'il suffit d'un seul certificat pour l'ensemble des hôtes virtuels d'un serveur web.

Mais il faut pour cela paramétrer plus finement le fichier `openssl.conf`.

- Générez la demande de certificat pour le serveur web (sur la machine serveur web). Visualisez le résultat.
- Envoyez par SSH ce fichier de demande à la machine CA, servant d'autorité de certification.

La troisième et dernière étape consiste à signer ce certificat. Cette étape (comme celle concernant la génération d'un certificat d'autorité de certification) n'aurait pas lieu d'être si nous faisons appel à une autorité de certification externe à laquelle on aurait tout simplement envoyé (selon une procédure définie par l'autorité de certification) la demande de certificat.

Troisième étape : production du certificat signé par l'autorité de certification

Cette signature et la production du certificat se réalisent avec la commande suivante :

```
openssl ca -policy policy_anything -out chemin/nom_du_certificat.pem -infiles chemin/nom_fichier_dem.pem
```

ca : c'est l'autorité de certification qui agit.

-policy policy_anything : c'est la clause `policy_anything` du fichier de configuration `openssl.cnf` qui sera utilisée. Dans notre cas seul le « Common Name » sera testé.

-out chemin/nom_du_certificat.pem : le certificat généré et à envoyer

-infiles chemin/nom_fichier_dem.pem : le fichier de demande de certificat utilisé pour générer le certificat.

Le certificat du serveur (que l'on doit normalement envoyer à celui qui nous l'a demandé) a bien été créé mais il y a aussi une copie du certificat « **01.pem** » qui a été automatiquement créé dans **newcerts**. L'autorité de certification le garde car elle a besoin de cet original en cas de révocation...

Après avoir reçu, selon la procédure définie, la demande de certificat :

- Générez le certificat du serveur Web que vous nommerez *servwebcert.pem*.

La commande de génération du certificat du serveur Web produit la sortie « écran » suivante :

```
Using configuration from /usr/lib/ssl/openssl.cnf
Enter pass phrase for /etc/ssl/private/cakey.pem:
Check that the request matches the signature
Signature ok
Certificate Details:
  Serial Number: 1 (0x1)
  Validity
    Not Before: Apr  2 21:32:43 2012 GMT
    Not After : Apr  2 21:32:43 2013 GMT
  Subject:
    countryName           = FR
    stateOrProvinceName   = France
    localityName          = Montauban
    organizationName      = SODECAF
    commonName            = sodecaf.fr
    emailAddress          = webmaster@sodecaf.fr
  X509v3 extensions:
    X509v3 Basic Constraints:
      CA:FALSE
    Netscape Comment:
      OpenSSL Generated Certificate
    X509v3 Subject Key Identifier:
      7B:B2:96:A9:FC:05:74:60:C0:35:E3:48:D0:BF:83:0B:C3:6D:F4:5A
    X509v3 Authority Key Identifier:
      keyid:AF:34:68:0A:D4:FA:8F:09:5E:1F:B2:2D:31:38:4C:44:1C:0D:C8:A6

Certificate is to be certified until Apr  2 21:32:43 2013 GMT (365 days)
Sign the certificate? [y/n]:y

1 out of 1 certificate requests certified, commit? [y/n]y
Write out database with 1 new entries
Data Base Updated
```

Vous pouvez aussi consulter le contenu du certificat du serveur web généré.

En fonction de la sortie écran et/ou du contenu du certificat du serveur, répondez aux questions suivantes :

- Quelle est la clé privée utilisée pour signer le certificat ?
- Comment la commande openssl « sait » laquelle utiliser ?
- Quelle est la valeur du numéro de série du certificat ?
- Quelle est la durée de validité du certificat ?
- Relevez et expliquez le contenu des fichiers *index.txt* et *serial*.
- Quelle a été l'action précise de la dernière phrase affichée « Data Base Updated » ?
- Copiez maintenant ce certificat dans le dossier */etc/ssl/certs* du serveur web.

Il est maintenant nécessaire de configurer le serveur Web Apache2 afin qu'il utilise le protocole HTTPS.

Configuration d'APACHE2 avec mod_ssl

Le module ssl d'Apache2 implémente le protocole HTTPS. L'activation de ce module permet en outre à Apache2 d'écouter sur le port 443 qui est le port par défaut pour HTTPS.

Pour activer le module ssl sous Apache2 :

```
# a2enmod ssl
```

Il faut donc préciser systématiquement les ports dans la configuration des hôtes virtuels : ceci se fait dans le fichier */etc/apache2/sites-available/votre_fichier_de_configuration.conf*

```
<VirtualHost * : 80> à remplacer par <VirtualHost * : 443>
```

Pour chaque hôte virtuel devant utiliser le protocole HTTPS, il est nécessaire d'ajouter un certain nombre de directives.

Après avoir changé le port 80 en 443, les directives à ajouter entre les balises sont les suivantes :

```
SSLEngine on
SSLCertificateFile chemin_vers_le_certificat_du_serveur_web
SSLCertificateKeyFile chemin_vers_la_clé_privé_du_serveur_web
```

Pour rediriger toutes les requêtes HTTP en HTTPS, on utilise la directive Rewrite :

```
<VirtualHost *:80>
    RewriteEngine On
    RewriteCond %{HTTPS} !=on
    RewriteRule ^/?(.*) https://%{SERVER_NAME}$1 [R,L]
</VirtualHost>
```

Il faut alors activer l'utilisation de cette directive :

```
# a2enmod rewrite
```

Remarque :

Les erreurs de configuration sont fréquentes, il faut s'aider du fichier d'activité `/var/log/apache2.log`. Il est même possible d'isoler les erreurs relatives à HTTPS (c'est beaucoup mieux pour « debugger ») avec la directive :

ErrorLog `/var/log/apache2/error_ssl.log` (attention : il faut créer le fichier `error_ssl.log`).

Et si ce n'est toujours pas suffisant, vous pouvez même mettre la directive « LogLevel » à « debug » (LogLevel debug) ou « info » (LogLevel info) à la place de la directive « LogLevel warn » puis dans une console : `tail -f /var/log/apache2/error_ssl.log` pour voir quels sont les problèmes qui surviennent quand vous rechargez la lecture de la configuration :

Une autre commande peut vous aiguiller sur une éventuelle cause d'erreur :

openssl s_client -connect nom_dns:443

- Activez le module « ssl » et redémarrez le serveur WEB.
- Ouvrez le fichier de configuration `/etc/apache2/site-available/000-default.conf` et configurez le serveur web pour qu'il soit accessible qu'en HTTPS.
- Redémarrez le service Apache2 et s'il n'y a pas d'erreurs testez une connexion en HTTPS ; l'alerte de sécurité (warning) au niveau du certificat est « normal » (voir ci-après).

Test du serveur Web sécurisé

Lorsque vous tentez d'accéder à votre site Web sécurisé (par exemple, avec l'URL **https://@IP_du_serveur_web**), le navigateur renvoie une alerte de sécurité qui se présente ainsi sur le navigateur « firefox » : il faut ajouter une exception pour ce certificat puisque le navigateur ne connaît pas notre autorité de certification.

- Testez l'accès en HTTPS à votre site web à partir d'une machine cliente Windows ou Linux.
- Dans le navigateur, visualiser les informations sur le certificat et l'autorité de certification.

ressources :

<https://www.reseaucerta.org/content/service-web-securise>

**Cette connexion n'est pas certifiée**

Vous avez demandé à Iceweasel de se connecter de manière sécurisée à `gestiontrasserv1.gsb.coop` mais nous ne pouvons pas confirmer que votre connexion est sécurisée.

Normalement, lorsque vous essayez de vous connecter de manière sécurisée, les sites présentent une identification certifiée pour prouver que vous vous trouvez à la bonne adresse. Cependant, l'identité de ce site ne peut pas être vérifiée.

Que dois-je faire ?

Si vous vous connectez habituellement à ce site sans problème, cette erreur peut signifier que quelqu'un essaie d'usurper l'identité de ce site et vous ne devriez pas continuer.

[Sortir d'ici](#)

Détails techniques

`gestiontrasserv1.gsb.coop` utilise un certificat de sécurité invalide.

Le certificat n'est pas sûr car aucune chaîne d'émetteurs de confiance n'est fournie.

(Code d'erreur : `sec_error_unknown_issuer`)

Je comprends les risques

Si vous comprenez ce qui se passe, vous pouvez indiquer à Iceweasel de commencer à faire confiance à l'identification de ce site. **Même si vous avez confiance en ce site, cette erreur pourrait signifier que quelqu'un est en train de pirater votre connexion.**

N'ajoutez pas d'exception à moins que vous ne connaissiez une bonne raison pour laquelle ce site n'utilise pas d'identification certifiée.

[Ajouter une exception...](#)